



MBA AI ENGINEERING & MULTI-AGENTS

Disciplina: Governance & Responsible AI

Turma 1AIE

Trabalho Final

Plano de Governança de Dados e IA

Caso: **Quantum Commerce**

GRUPO

Grupo (número): 2

Integrantes (RM e Nome):

1. **371431** Ksenia Aleksandrovna Busquet
2. **374349** Henrique Guilherme Dos Santos Mongruel Arduini
3. **373230** Renato de Jesus Rocha
4. **371147** Samuel Silvério Andrade Cupertino

Data de entrega: ____ / ____ / ____

Professor: Sergio Mantovani

Índice

Sumário do documento. Manter as seções abaixo, na ordem indicada. Ao finalizar, atualize números de página.

1. Contexto Quantum Commerce
2. Inventário e Classificação de Casos de Uso
3. Plano de Governança de Dados
4. Plano de Responsible AI
5. Aprofundamento: Riscos e Mitigações de Agentic AI
6. Modelo Organizacional e Operacional
7. Roadmap 90 / 180 / 365 dias
8. Referências

1. Contexto Quantum Commerce

1.1 Caracterização da empresa

A **Quantum Commerce** é um grupo varejista omnichannel de médio-grande porte, com atuação nacional no Brasil, combinando aproximadamente 450 lojas físicas, plataforma de e-commerce própria e um marketplace com mais de 8 mil sellers parceiros. O portfólio cobre eletroeletrônicos, moda, casa e decoração e esporte/lazer, com GMV anual da ordem de R\$ 15-20 bilhões (ordem de grandeza, não valor auditado) e cerca de 12 mil funcionários diretos.

Além da operação de varejo, a Quantum oferece produtos financeiros embarcados sob a marca **"Quantum Pay"**: cartão de crédito private label e parcelamento no modelo BNPL (buy now, pay later), operados por uma Sociedade de Crédito, Financiamento e Investimento (SCFI) do próprio grupo. Essa frente financeira processa dezenas de milhares de decisões de crédito por mês e concentra hoje a maior parte dos dados sensíveis e das decisões automatizadas de alto impacto da empresa — motivo pelo qual o tema de IA responsável ganhou prioridade executiva.

Canais: lojas físicas, app mobile, site de e-commerce, marketplace (venda própria + sellers terceiros) e SAC via WhatsApp/chat. Dados processados: cadastro e transações de clientes (CPF, endereço, histórico de compra), dados de pagamento e crédito (renda declarada, score, histórico de inadimplência), dados de navegação/comportamento (clickstream, carrinho, avaliações), dados de sellers e catálogo, e dados logísticos (rastreamento de entrega, estoque).

Maturidade tecnológica atual: a Quantum opera um modelo de credit scoring tradicional (regressão logística/gradient boosting) em produção há cerca de 3 anos, sem processo formal de auditoria de viés; testa em piloto restrito um chatbot de atendimento baseado em LLM com RAG sobre sua base de conhecimento; e iniciou um piloto de agente autônomo de pós-venda (cancelamento, troca, reembolso) que ainda não possui framework de governança, identidade não-humana nem observabilidade formal — lacuna que motiva este plano.

1.2 Premissas adotadas

Stack de nuvem principal: AWS (S3, Redshift, SageMaker) para dados e cargas analíticas; Azure (Azure OpenAI Service, Microsoft Purview, Microsoft Entra ID) para IA generativa/agêntica e catálogo de dados — arquitetura multicloud comum em grandes varejistas brasileiros.

ERP: SAP. **CRM:** Salesforce. **Data Lake/Lakehouse:** Databricks sobre AWS, com camadas Bronze/Silver/Gold.

Aproximadamente 12.000 funcionários, sede em São Paulo, operação restrita ao território nacional (sem transferência internacional de dados relevante, exceto para provedores de nuvem/IA, tratada via cláusulas contratuais padrão e adequação LGPD Art. 33).

A Quantum já possui um Encarregado de Proteção de Dados (DPO) formalmente nomeado e um programa básico de adequação à LGPD, mas não possui ainda estrutura de governança de IA, comitê de IA ou inventário formal de modelos — é o que este plano constitui.

A operação de crédito (Quantum Pay) é regulada por uma SCFI própria, sujeita à supervisão do Banco Central do Brasil, o que eleva o padrão de exigência de auditabilidade e explicabilidade dos modelos de crédito.

Não foram utilizados dados financeiros reais da empresa; todos os números citados neste plano são ordens de grandeza plausíveis para uma varejista desse porte, usados apenas para ilustrar escala e priorização.

1.3 Stakeholders relevantes

CEO / Conselho de administração — patrocinador final da governança de IA, responsável por reportar risco de IA ao mercado e reguladores.

CDO/CTO — dono da arquitetura e qualidade de dados que alimentam os modelos; participa do Comitê Executivo de IA.

CISO — responsável por segurança de dados, identidade não-humana de agentes e resposta a incidentes de IA.

DPO / Jurídico — garante conformidade com LGPD e PL 2338, avalia RIPD e responde à ANPD.

Diretoria de crédito e risco (Quantum Pay) — dona de negócio do motor de crédito, sujeita à supervisão do Bacen.

Diretoria de marketing/CRM — dona dos casos de recomendação, precificação e geração de conteúdo.

Diretoria de operações e Supply Chain — impactada pelo agente de pós-venda/logística reversa.

Atendimento ao cliente / CX — opera o chatbot e recebe escalonamentos humanos (HITL).

Clientes finais — titulares dos dados, afetados diretamente por decisões de crédito, recomendação e atendimento automatizado.

Sellers do marketplace — fornecem dados de catálogo e são afetados pelo gerador de conteúdo e por políticas de moderação.

Reguladores — ANPD (LGPD), Banco Central/eventual Susep (crédito), Procon/órgãos de defesa do consumidor.

Fornecedores de tecnologia e IA — provedores de nuvem (AWS, Azure) e de modelos de LLM, partes da cadeia de responsabilidade fornecedor/operador do PL 2338.

2. Inventário e Classificação de Casos de Uso

2.1 Tabela-síntese de casos de uso

#	Nome do caso	Tipo de IA	Valor de negócio	Dados que toca	Ações que executa	Risco (Alto / Médio / Baixo)	Top 3 riscos OWASP / NIST
1	Motor de aprovação de crédito (Quantum Pay)	IA preditiva tradicional (gradient boosting / regressão logística)	Decide aprovação, limite e taxa de ~40 mil solicitações de crédito/mês; reduz tempo de decisão de dias para segundos e amplia conversão de vendas parceladas.	CPF, renda declarada, histórico de pagamento, dados cadastrais (idade, profissão, tempo de emprego), bureau de crédito externo, histórico de compras Quantum.	Aprova/nega crédito e define limite/taxa; decisão majoritariamente automatizada, com revisão humana apenas acima de um teto de valor.	Alto	Viés socioeconômico/discriminação indireta (Fairness — análogo aos casos Apple Card e Upstart); LGPD Art. 20 (revisão humana de decisão automatizada); NIST RMF — “Justo, com preconceito gerenciado” e explicabilidade insuficiente ao titular.
2	Motor de recomendação e precificação dinâmica	IA preditiva (collaborative filtering / machine learning clássico)	Personaliza vitrine do e-commerce/app e ajusta preço dinamicamente; referência de mercado indica ganho de 5-10% em margem bruta e conversão.	Histórico de navegação/compra, carrinho, avaliações, dados de estoque e preço de concorrentes.	Ordena catálogo, ajusta preço dentro de faixas pré-aprovadas, dispara promoções automáticas.	Médio	Discriminação de preço por perfil (fairness em pricing); qualidade/atualidade de dados de estoque (Data Quality — Timeliness); NIST RMF — “Válido e confiável” frente a drift de demanda.

#	Nome do caso	Tipo de IA	Valor de negócio	Dados que toca	Ações que executa	Risco (Alto / Médio / Baixo)	Top 3 riscos OWASP / NIST
3	Chatbot de atendimento (SAC) via LLM + RAG	IA generativa	Atendimento 24/7; referência de mercado (Gartner 2024) indica redução de até 60% no tempo de espera; desafoga a central humana.	Histórico de pedidos do cliente, base de conhecimento (políticas de troca/devolução/garantia), CPF para autenticação.	Responde dúvidas, consulta status de pedido, inicia solicitação de troca/reembolso, com handoff humano acima de um teto de valor.	Alto	Alucinação de política de reembolso (precedente direto: caso Air Canada v. Moffatt); OWASP LLM01 Prompt Injection e LLM09 Misinformation; LGPD — uso de dados pessoais para autenticação/atendimento.
4	Gerador de descrições e conteúdo para sellers do marketplace	IA generativa	Acelera publicação de novos anúncios por sellers (de horas para minutos), padroniza qualidade de conteúdo e melhora SEO/conversão.	Fotos e especificações de produto enviadas pelo seller, dados de catálogo/categoria.	Gera título, descrição, tags e sugestão de preço de referência para revisão do seller antes da publicação.	Médio	Uso indevido de imagens/propriedade intelectual de terceiros (OWASP LLM03 Supply Chain — ponto sensível também no PL 2338); desinformação sobre especificações de produto (Misinformation/proteção ao consumidor); consistência de catálogo (Data Quality).
5	Agente autônomo de pós-Venda e logística reversa	IA agêntica (multiagent e: triagem + decisão + execução)	Automatiza troca/devolução/reembolso ponta a ponta, integrando SAC, estoque e financeiro; reduz custo operacional e tempo de resolução.	Histórico de pedido, imagens do produto devolvido, políticas comerciais, dados financeiros para estorno.	Avalia elegibilidade, aciona logística reversa, autoriza estorno até um teto e escala para humano em casos ambíguos ou acima do teto.	Alto	ASI01 Agent Goal Hijack (instrução maliciosa embutida em mensagem de cliente); ASI02 Tool Misuse (execução de estorno indevido); ASI09 Human-Agent Trust Exploitation.

2.2 Justificativa de priorização

A priorização seguiu a lógica de **valor x viabilidade x risco** discutida em aula (matriz custo/risco/valor). O motor de aprovação de crédito foi priorizado por já estar em produção e concentrar o maior risco regulatório e de imagem (decisão automatizada sobre pessoas, sob supervisão do Bacen e da LGPD) — é “alto risco, alto valor”, exigindo governança imediata.

O chatbot de atendimento e o agente de pós-venda foram priorizados por já estarem em piloto e por serem os primeiros casos generativo/agêntico com potencial de dano direto ao cliente (paralelo aos casos Air Canada e EchoLeak), exigindo guardrails antes de qualquer escala.

O motor de recomendação/precificação e o gerador de conteúdo para sellers, apesar de risco menor, foram incluídos por já operarem em escala e por garantirem cobertura dos três paradigmas de IA (preditiva, generativa e agêntica) exigidos pelo trabalho — são “quick wins” de governança, com custo de mitigação relativamente baixo.

Casos de menor maturidade ou escala (ex.: previsão isolada de estoque) ficaram fora deste primeiro ciclo do inventário, sem prejuízo de inclusão em ciclos futuros conforme o AI Risk Office (seção 6) amplie a cobertura.

3. Plano de Governança de Dados

3.1 As 11 disciplinas DAMA aplicadas à Quantum Commerce

Disciplina DAMA	Aplicação na Quantum Commerce	Responsável (papel)	Ferramentas / processos
Data Architecture	Arquitetura de dados unificada entre a operação de varejo (SAP/Databricks) e a operação financeira (Quantum Pay), com camadas Bronze/Silver/Gold no lakehouse, permitindo que os mesmos dados de cliente alimentem o motor de crédito e o de recomendação sem duplicação.	Head de Arquitetura de Dados (sob o CDO)	Databricks Lakehouse sobre AWS; documentação de arquitetura em padrão C4; dbt para modelagem de pipelines.
Data Modeling & Design	Modelagem de entidades mestras (Cliente, Produto, Pedido, Conta de Crédito) em padrão canônico único, evitando que Crédito e Marketing modelem "Cliente" de formas incompatíveis.	Arquitetos de dados / Data Modelers por domínio	dbt para modelagem transformacional; ferramentas de modelagem conceitual (ex.: dbdiagram, ERwin).
Data Storage & Operations	Armazenamento em camadas conforme sensibilidade (ver 3.2), com backup, retenção e ciclo de vida definidos por tipo de dado (ex.: dados de navegação com retenção de 12 meses; dados de crédito conforme obrigação regulatória).	Engenharia de Dados / Infraestrutura Cloud	AWS S3 com lifecycle policies; Redshift; monitoramento de operação via Databricks.
Data Security	Controle de acesso baseado em papel (RBAC) e, para agentes de IA, identidade não-humana (ver 5.2); criptografia em repouso e trânsito para dados de crédito e PII.	CISO / Segurança da Informação	AWS KMS; Microsoft Purview DLP; Microsoft Presidio para detecção de PII em pipelines de IA.
Data Integration & Interoperability	Integração entre SAP (ERP/estoque), Salesforce (CRM), bureau de crédito externo e plataforma de IA generativa via pipelines versionados, evitando falhas de conversão de unidade/formato entre sistemas (lição do caso Mars Climate Orbiter discutido em aula).	Engenharia de Dados / Integração	Databricks Workflows; conectores tipo Fivetran/Airbyte; API Gateway.
Documents & Content Management	Gestão do conteúdo usado como base de conhecimento do chatbot (políticas de troca, garantia, FAQ) e do catálogo gerado por IA (caso 4), com versionamento e trilha de aprovação editorial antes da publicação.	Time de Conteúdo/CX, com curadoria do time de dados	Base vetorial indexada para RAG; CMS do e-commerce com controle de versão.

Disciplina DAMA	Aplicação na Quantum Commerce	Responsável (papel)	Ferramentas / processos
Reference & Master Data	Consolidação de golden record de cliente único entre loja física, e-commerce, marketplace e Quantum Pay — hoje fragmentado, replicando o caso real discutido em aula (múltiplos cadastros do mesmo CPF em produtos diferentes).	MDM Lead	Databricks Unity Catalog + rotina de deduplicação por CPF/telefone/e-mail.
Data Warehousing & BI	Camada Gold do lakehouse alimenta dashboards executivos (GMV, inadimplência, NPS) e datasets de treino dos modelos de IA.	BI / Analytics	Databricks SQL; Power BI.
Metadata Management	Catálogo de dados único descrevendo origem, sensibilidade, dono e qualidade de cada dataset usado para treinar ou alimentar modelos de IA — pré-requisito para o inventário de IA (seção 2) e para a documentação técnica exigida pelo PL 2338/EU AI Act.	Data Governance / Data Steward por domínio	Microsoft Purview (catálogo + lineage), com tags de sensibilidade do item 3.2.
Data Quality	Monitoramento contínuo das 6 dimensões de qualidade (ver 3.3), com foco prioritário nos dados que alimentam o motor de crédito e o RAG do chatbot, onde erros se traduzem diretamente em decisão errada ou alucinação.	Data Quality Lead + Stewards de negócio	Great Expectations / checks nativos do Databricks; dashboards de DQ com alertas automáticos.

3.2 Política de classificação de dados

Nível	Definição	Exemplos	Controles obrigatórios
Public	Dado que pode ser divulgado publicamente sem risco.	Catálogo de produtos, preços públicos, conteúdo de marketing.	Nenhum controle de acesso especial; revisão de marca/compliance antes de publicação.
Internal	Dado de uso interno, sem risco individual mas com valor competitivo.	Relatórios de vendas agregados, dashboards de estoque, playbooks operacionais.	Acesso restrito a colaboradores autenticados (SSO); NDA em contratos com terceiros.

Nível	Definição	Exemplos	Controles obrigatórios
Confidential	Dado sensível ao negócio ou parcialmente identificável, cujo vazamento gera dano reputacional ou concorrencial.	Contratos com sellers, margens por categoria, parâmetros de modelos de IA, prompts de sistema.	RBAC granular; criptografia em repouso; DLP (Microsoft Purview); aprovação formal para exportação; NDA.
Restricted / PII	Dado pessoal ou pessoal sensível (LGPD Art. 5º/11), cujo vazamento ou uso indevido gera dano ao titular e risco regulatório direto.	CPF, renda, score de crédito, dados biométricos de autenticação, eventuais dados de saúde em disputas de garantia.	Criptografia em repouso e trânsito; mascaramento/anonimização em dev/teste; detecção automática de PII (Presidio/Purview DLP); acesso just-in-time e logado; base legal documentada; retenção limitada; DPIA/RIPD obrigatório antes de uso em treino de modelo.

3.3 Qualidade de dados

Adotamos as 6 dimensões de qualidade de dados trabalhadas em aula (DAMA-DMBOK): **Precisão, Completude, Consistência, Atualidade, Validade e Unicidade** — aplicadas prioritariamente aos dados que alimentam o motor de crédito (atributos cadastrais e financeiros) e a base de conhecimento do chatbot (RAG).

Completude: % de campos obrigatórios preenchidos no cadastro de crédito (ex.: confirmação de CPF, renda declarada) — meta $\geq 98\%$.

Precisão: % de CPFs validados contra a Receita Federal — meta $\geq 99,5\%$.

Consistência: % de registros de cliente com endereço/CPF idênticos entre CRM, e-commerce e Quantum Pay — meta $\geq 97\%$, com golden record centralizado (ver 3.1).

Atualidade: tempo médio entre atualização de estoque no ERP e reflexo na vitrine — meta ≤ 15 minutos.

Validade: % de registros dentro de regras de domínio (ex.: idade entre 18 e 100 anos) — meta $\geq 99\%$.

Unicidade: número de registros de cliente duplicados a cada 10 mil CPFs — meta $\leq 0,5\%$.

Reporte: dashboard de Data Quality (Databricks/Great Expectations) com revisão mensal pelo Data Governance e alerta automático quando qualquer dimensão cai abaixo da meta por 2 ciclos consecutivos, escalando ao Data Steward do domínio.

3.4 LGPD e direitos dos titulares

O plano garante os direitos do titular (LGPD Art. 18) por canal de autoatendimento integrado ao chatbot e ao DPO: acesso (extrato de dados tratados, incluindo quais modelos de IA usaram o dado do titular), correção (atualização cadastral com propagação ao golden record), exclusão (anonimização — não deleção física — para preservar séries históricas de risco de crédito sob base legal de obrigação regulatória/legítimo interesse), portabilidade (exportação estruturada de dados de compra e crédito) e revisão humana de decisão automatizada (Art. 20), obrigatória para toda negativa de crédito acima de determinado valor ou mediante solicitação do cliente.

Bases legais por finalidade: execução de contrato (compra, entrega), cumprimento de obrigação legal/regulatória (dados de crédito, retenção fiscal), legítimo interesse (personalização e antifraude, com teste de balanceamento documentado) e consentimento específico (uso de histórico de atendimento para treinar modelos de IA generativa, quando a finalidade original não cobrir esse uso — Art. 6º, princípio da finalidade).

Toda solicitação de crédito de alto volume/impacto (motor de crédito) e todo caso de uso que trate dados sensíveis em larga escala (ex.: RAG do chatbot com histórico de atendimento) exige Relatório de Impacto à Proteção de Dados (RIPD, Art. 37) antes do go-live, sob responsabilidade do DPO em conjunto com o AI Risk Office (seção 6).

4. Plano de Responsible AI

4.1 Princípios de Responsible AI da Quantum

Princípio	Definição na Quantum
Justiça e Inclusão	O motor de crédito e o de recomendação não podem penalizar clientes por proxies socioeconômicos (CEP, tipo de dispositivo de acesso) de forma a replicar discriminação histórica — verificado via auditoria de fairness por subgrupo antes de cada retreino.
Transparência e Explicabilidade	Toda decisão automatizada de crédito é documentada com Model Card e explicação individual (SHAP) disponível ao cliente e ao regulador; o chatbot e o agente de pós-venda sempre se identificam como IA (requisito de risco limitado do EU AI Act e do PL 2338).
Privacidade e Segurança	Dados de crédito e PII seguem a classificação Restricted (3.2), com mascaramento em ambientes de teste, guardrails contra prompt injection no chatbot e no agente de pós-venda, e testes de red team antes de cada nova versão em produção.
Confiabilidade e Robustez	Modelos de crédito e o RAG do chatbot são testados contra dados fora de distribuição (novos perfis de cliente, gírias regionais) e monitorados continuamente quanto a drift, com fallback para atendimento humano quando a confiança do modelo é baixa.
Accountability	Cada caso de uso do inventário (seção 2) tem um dono de negócio (accountable) registrado no AI Register, evitando o “accountability gap” — ninguém pode alegar que “foi a IA que decidiu” sem um humano responsável identificado.
Supervisão Humana (HITL)	Nível de supervisão proporcional ao risco: aprovação humana obrigatória (HUMAN-IN) para estornos/crédito acima de teto definido; monitoramento com poder de intervenção (HUMAN-ON) para o chatbot; auditoria por amostragem (HUMAN-OUT) para recomendação de produtos.
Sustentabilidade / Impacto social	Escolha de modelos e infraestrutura considerando eficiência computacional (modelos menores/fine-tuned em vez de LLMs de fronteira quando suficiente) e avaliação do impacto do motor de crédito sobre inclusão financeira de clientes de menor renda, evitando exclusão automatizada em massa.

4.2 Controles práticos por categoria de risco

Categoria de risco	Controles técnicos	Controles de processo	Ferramentas nomeadas
Vieses e injustiça	Auditoria de fairness (demographic parity, equalized odds) antes do deploy e trimestralmente em produção; mitigação in-processing (reweighing) e pós-processamento (threshold optimization) no motor de crédito.	AI Risk Office/comitê de ética revisa métricas de fairness por subgrupo antes de aprovar novo modelo de crédito; trilha de decisão documentada no AI Register.	Fairlearn, AI Fairness 360 (IBM), Amazon SageMaker Clarify.
Alucinação / output incorreto	RAG com citação obrigatória de fonte no chatbot; validação programática de outputs (Guardrails AI/Pydantic); LLM-as-judge (RAGAS) em pipeline de CI/CD antes de nova versão de prompt.	Revisão humana obrigatória de qualquer resposta que mencione política de reembolso/garantia não confirmada pela base oficial; hallucination rate como KPI de produto.	RAGAS, Guardrails AI, base vetorial (Pinecone/OpenSearch).
Privacidade e PII	Deteção e mascaramento automático de PII em prompts/logs (Microsoft Presidio); criptografia de dados de crédito; differential privacy em datasets de treino quando aplicável.	RIPD obrigatório para casos que tratam dados sensíveis (3.4); DPO com poder de veto sobre uso de dado pessoal em treino de modelo.	Microsoft Presidio, Microsoft Purview DLP, Azure AI Language PII detection.
Segurança e adversarial	Guardrails de input/output em 3 camadas (regex, classificador, LLM-judge) no chatbot e no agente de pós-venda; sandboxing com privilégio mínimo para ferramentas do agente.	Red teaming trimestral (testes de prompt injection/jailbreak) antes de releases; playbook de resposta a incidente de IA.	NVIDIA NeMo Guardrails, PyRIT (Microsoft), Garak (NVIDIA), Lakera Guard.
Transparência	Model Cards e System Cards para cada modelo em produção; explicações locais (SHAP) disponíveis via API para o time de atendimento e para o cliente que contesta uma decisão.	Documentação técnica obrigatória antes do deploy (alinhada ao Art. 11 do EU AI Act e ao PL 2338); publicação interna do inventário de IA.	SHAP, InterpretML, templates de Model Card (NIST).
Confiabilidade e drift	Monitoramento contínuo de data drift e performance (accuracy, hallucination rate) com alerta automático; retreino programado do motor	Gate de aprovação humana para qualquer retreino/mudança de modelo em produção; relatório de performance ao AI Risk Office.	Evidently AI, DeepChecks, MLflow Model Registry.

Categoria de risco	Controles técnicos	Controles de processo	Ferramentas nomeadas
	de crédito a cada trimestre ou quando o drift excede o threshold.		

5. Aprofundamento: Riscos e Mitigações de Agentic AI

5.1 Mapeamento OWASP Agentic Top 10 → Quantum Commerce

ID	Risco Agentic	Mitigação proposta	Ferramenta
ASIO 1	Agent Goal Hijack	Alta relevância — o agente de pós-venda lê mensagens livres do cliente, superfície direta para injeção de instrução oculta (paralelo ao caso EchoLeak, M365 Copilot). Mitigação: validação da intenção declarada vs. ação solicitada; tratamento de todo texto do cliente como não confiável; trava de escopo do agente (não pode alterar suas próprias instruções).	Azure AI Content Safety / Prompt Shields; system prompt versionado com change management.
ASIO 2	Tool Misuse & Exploitation	Alta relevância — o agente possui ferramenta de estorno financeiro, alvo direto de abuso. Mitigação: princípio do menor privilégio (ferramenta de estorno limitada a teto de valor), allowlist de ações, aprovação humana acima do teto.	API Gateway com políticas de acesso + Guardrails AI para validação de schema de chamada + HITL obrigatório.
ASIO 3	Identity & Privilege Abuse	Alta relevância — o agente autentica-se em sistemas de estoque, financeiro e CRM. Mitigação: identidade não-humana própria por agente (nunca reaproveitar credencial de sistema genérico), escopo OAuth mínimo, rotação de token (ver 5.2).	Microsoft Entra Agent ID.
ASIO 4	Agentic Supply Chain Vulnerabilities	Média relevância — dependência de bibliotecas/orquestradores de terceiros e do modelo de LLM hospedado. Mitigação: verificação de origem de pacotes, uso apenas de provedores de modelo homologados, SBOM de componentes de IA.	Registro interno de MCP servers/plugins homologados; scanning de dependências (ex.: Snyk).

ID	Risco Agentic OWASP	Mitigação proposta	Ferramenta
ASIO 5	Unexpected Code Execution (RCE)	Baixa relevância — o agente de pós-venda não possui ferramenta de interpretador/execução de código arbitrário; risco residual apenas se essa capacidade for adicionada no futuro. Mitigação preventiva: sandbox isolado caso essa capacidade seja incorporada.	Contêiner isolado sem acesso à rede além de allowlist (aplicável se a capacidade for adicionada).
ASIO 6	Memory & Context Poisoning	Alta relevância — a base de conhecimento (RAG) pode ser contaminada por conteúdo malicioso submetido por sellers ou por interações anteriores mal higienizadas. Mitigação: sanitização de conteúdo antes da indexação, versionamento com rollback, isolamento por tenant (seller vs. base oficial).	Pipeline de ingestão com validação (Guardrails AI) + base vetorial com controle de acesso (Pinecone/OpenSearch).
ASIO 7	Insecure Inter-Agent Communication	Média relevância — hoje o agente de pós-venda opera isolado, mas a arquitetura prevê orquestração futura com o chatbot de atendimento. Mitigação: autenticação mútua entre agentes, assinatura de mensagens, Zero Trust entre agentes (cada agente tratado como não confiável por padrão).	mTLS entre serviços; OpenTelemetry para rastreo de mensagens inter-agente.
ASIO 8	Cascading Failures	Média relevância — erro do agente de triagem pode se propagar para o agente de execução de estorno. Mitigação: circuit breakers, validação intermediária de outputs antes de repassar ao próximo passo, limite de iterações.	Orquestrador com circuit breaker (ex.: LangGraph) + LangSmith/Langfuse para trace.
ASIO 9	Human-Agent Trust Exploitation	Alta relevância — o cliente pode ser induzido a confiar cegamente no agente, ou um golpista pode se passar pelo canal oficial (“fraude do CEO 2.0” aplicada a atendimento). Mitigação: identificação clara de que é um agente de IA, confirmação fora de banda para estornos de valor alto, HITL real (não “rubber-stamp”).	Selo de identificação de IA no canal + fluxo de confirmação via app autenticado.
ASI1 0	Rogue Agents	Média relevância — risco de deriva comportamental caso o agente “aprenda” a contornar regras de negócio para otimizar a métrica de resolução. Mitigação: baseline comportamental com detecção de desvio, kill-switch centralizado, avaliação contínua contra jailbreaks conhecidos.	Dashboards de observabilidade comportamental (Arize Phoenix) + kill-switch operado pelo AI Risk Office.

5.2 Identidade não-humana (NHI) para agentes

Cada agente de IA da Quantum (pós-venda e, futuramente, vendas/atendimento) recebe identidade não-humana própria via Microsoft Entra Agent ID, distinta das credenciais de usuários humanos — eliminando o padrão hoje comum (e arriscado) de reaproveitar login de sistema genérico.

Lifecycle de credenciais: provisionamento com escopo mínimo definido por ferramenta (ex.: o agente de pós-venda tem apenas leitura no CRM e escrita limitada no financeiro, até um teto de valor); acesso just-in-time, com tokens de curta duração renovados a cada sessão; revisão trimestral de permissões pelo AI Risk Office; e processo formal de “aposentadoria” (retirement) de agentes descontinuados, evitando o problema de “agentes órfãos”.

Todo acesso é logado com correlation-id, permitindo auditoria de qual agente executou qual ação em nome de qual processo de negócio. Alternativas avaliadas: Okta Identity for Agents e AWS IAM Identity Center — descartadas nesta fase por já haver padronização em Microsoft Entra ID para identidade humana na Quantum.

5.3 Nível de autonomia por caso de uso

Motor de aprovação de crédito — HUMAN-IN para negativas de alto valor ou mediante contestação do cliente (LGPD Art. 20); demais decisões seguem HUMAN-ON com auditoria por amostragem. Justificativa: decisão de alto impacto sobre pessoas físicas, sob supervisão regulatória do Bacen.

Motor de recomendação/precificação — HUMAN-OUT (auditoria por amostragem mensal); ação reversível, baixo impacto individual, alto volume; faixas de variação de preço pré-aprovadas por Marketing/Pricing.

Chatbot de atendimento (SAC) — HUMAN-ON com HUMAN-IN para exceções de alto valor (reembolsos acima de teto, disputas); escalonamento automático (HUMAN-EX) quando a confiança do modelo é baixa ou o cliente demonstra insatisfação.

Gerador de conteúdo para sellers — HUMAN-ON com revisão por amostragem antes de publicação massiva; categorias sensíveis (ex.: saúde/beleza) exigem HUMAN-IN.

Agente autônomo de pós-venda — HUMAN-IN para estorno acima de teto ou troca de produto de alto valor; HUMAN-ON para o restante do fluxo (triagem, agendamento de coleta); HUMAN-EX para casos ambíguos identificados pelo próprio agente (ex.: indício de fraude).

5.4 Observabilidade e detecção em runtime

A observabilidade do agente de pós-venda e do chatbot segue os 4 pilares trabalhados em aula:

- **Logs** estruturados de cada decisão e chamada de ferramenta, com correlation-id de ponta a ponta e PII mascarada antes da gravação
- **Traces distribuídos (OpenTelemetry)** cobrindo toda a sessão, incluindo sub-agentes e ferramentas externas (CRM, financeiro, logística);
- **Métricas** em tempo real — chamadas de ferramenta por sessão, custo por interação, taxa de erro por ferramenta, latência (p50/p95/p99), hallucination rate do chatbot;

- **Comportamento** (baseline behavioral) — sequência típica de ações do agente e comprimento médio de trajetória, para detectar “agente errante” antes que cause dano.

Ferramentas: Langfuse (observabilidade open source, já validada em piloto), com avaliação para complementar com LangSmith (alertas configuráveis pelo time de negócio) ou Datadog (integração nativa com a infraestrutura já usada pela Quantum).

Deteção de cascading failures via circuit breakers por agente/ferramenta e validação intermediária (LLM-as-judge) entre etapas do fluxo de pós-venda; kill-switch centralizado operável pelo AI Risk Office, capaz de suspender um agente específico sem derrubar os demais.

Retenção de logs alinhada à política de classificação de dados (3.2); na ausência de regra específica de retenção no PL 2338, a Quantum optou por reter por 18 meses, dado o baixo custo de storage e o valor probatório em disputas/auditorias.

6. Modelo Organizacional e Operacional

6.1 Estruturas de governança propostas

A Quantum adota um modelo de governança em **3 camadas**, adaptado do modelo discutido em aula:

Camada estratégica — Comitê Executivo de IA, composto por CEO/COO, CDO, CISO, Diretor Jurídico/DPO, Diretor de Crédito e Risco e o Head de IA Responsável (AI Risk Office). Reúne-se trimestralmente para aprovar política de IA, apetite de risco e novos casos de uso de alto risco (ex.: novo modelo de crédito), e reporta ao Conselho de Administração semestralmente.

Camada de governança — AI Risk Office (função nova, reportando ao CDO com linha pontilhada para o Jurídico/DPO, evitando o conflito de interesse de quem entrega os projetos de IA também fiscalizar seus riscos). Reúne-se mensalmente para revisar o inventário de IA, métricas de fairness/qualidade/segurança e aprovar mudanças de risco médio.

Camada de execução — AI Champions em cada área de negócio (Crédito, Marketing, CX, Supply Chain), responsáveis pelo dia a dia dos modelos sob supervisão humana (HITL/HOTL), sem necessidade de passar por comitê para operações de rotina de baixo risco.

6.2 Papéis e responsabilidades

AI Risk Office Lead (equivalente a um Chief Responsible AI Officer) - lidera a governança de IA da Quantum, com senioridade para influenciar decisões de negócio.

Qualificação: experiência em risco/compliance de IA ou dados, conhecimento de ISO/IEC 42001, NIST AI RMF e LGPD.

Responsabilidades: manter o AI Register, aprovar/vetar novos casos de uso de alto risco, reportar ao Comitê Executivo.

Autoridade: pode suspender um caso de uso ou agente em produção (kill-switch) em caso de incidente.

Data Governance Lead (reporta ao CDO) - dono da qualidade, classificação e catálogo de dados.

Qualificação: experiência em DAMA-DMBOK e ferramentas de catálogo.

Responsabilidades: manter a política de classificação (3.2) e as métricas de qualidade (3.3).

Autoridade: aprova liberação de novos datasets para uso em modelos de IA.

DPO / Encarregado de dados - ponte entre a Quantum, os titulares e a ANPD.

Qualificação: formação jurídica ou em privacidade, certificação (ex.: CIPP/CIPM).

Responsabilidades: aprovar RIPD, monitorar bases legais, atender direitos dos titulares.

Autoridade: veto sobre uso de dado pessoal fora de finalidade declarada.

CISO / Security Lead para IA - responsável pela segurança de dados e pela segurança específica de agentes de IA (NHI, guardrails).

Qualificação: experiência em cibersegurança e, idealmente, em AI red teaming.

Responsabilidades: gerir identidade não-humana (5.2), coordenar red teaming trimestral.

Autoridade: bloqueia deploy de agente sem controlos mínimos de segurança.

AI Product Owner por caso de uso - dono de negócio de cada caso do inventário (ex.: Owner do motor de crédito).

Qualificação: conhecimento profundo do processo de negócio.

Responsabilidades: é o “accountable” registrado no AI Register (princípio de Accountability, 4.1); responde por incidentes do seu caso de uso.

MLOps / Agent Platform Engineer - mantém a infraestrutura de deploy, observabilidade e guardrails dos modelos e agentes.

Qualificação: experiência em MLOps/LLMOps.

Responsabilidades: implementar monitoramento (5.4), pipelines de CI/CD com testes de qualidade/segurança.

AI Champion de área de negócio - ponto focal de IA responsável dentro de Crédito, Marketing, CX e Supply Chain.

Qualificação: treinamento em AI Literacy oferecido pelo AI Risk Office.

Responsabilidades: primeira linha de deteção de problemas no uso diário dos modelos/agentes, escalonamento ao AI Risk Office.

6.3 Matriz RACI

Atividade / decisão	Board / CEO	Comitê de IA	AI Risk Office	Áreas de negócio	DPO / Jurídico	Segurança / CISO
Aprovar política de IA	A	R	C	I	C	C
Aprovar novo caso de uso	I	A	R	C	C	C
Auditoria de modelos em produção	I	I	A	C	C	R
Resposta a incidente de IA	I	I	A	R	C	R
Avaliação de impacto (LGPD/EU AI Act)	I	I	C	C	A	C
Aprovação de gastos com ferramentas	I	A	R	C	I	C
Reporte ao board	I	A	R	I	C	C

7. Roadmap 90 / 180 / 365 dias

Fase	Objetivo	Entregas concretas	Dependências	Responsável principal
90 dias – Quick wins	Estabelecer a fundação de governança e mapear o risco atual.	Constituição do Comitê Executivo de IA e do AI Risk Office; inventário inicial dos 5 casos de uso (seção 2) com registro no AI Register; política de classificação de dados (3.2) aprovada; auditoria de fairness inicial do motor de crédito em produção; guardrails básicos (Presidio + Content Safety) no chatbot piloto.	Patrocínio executivo (CEO/Conselho); disponibilidade do DPO e CISO para desenho conjunto; nenhuma aquisição de ferramenta nova é obrigatória nesta fase (uso de capacidades já disponíveis em Azure/AWS).	AI Risk Office Lead (a designar) + CDO.
180 dias – Capacidade média	Colocar os casos priorizados sob governança plena, com ferramentas ativas e times capacitados.	Model Cards para os 5 casos de uso; observabilidade (Langfuse) em produção no chatbot e no agente de pós-venda; identidade não-humana (Entra Agent ID) implementada; treinamento de AI Literacy para AI Champions; RACI (6.3) formalizado e publicado; RIPD concluído para o motor de crédito e o RAG do chatbot.	Contratação/licenciamento de ferramentas de observabilidade e guardrails; conclusão da integração de identidade não-humana com o Entra ID; orçamento aprovado na fase de 90 dias.	AI Risk Office + MLOps/Agent Platform Engineer + AI Champions.
365 dias – Maturidade alvo	Consolidar um processo contínuo de governança de IA, com métricas estáveis e reporte recorrente ao board.	Auditoria trimestral de fairness/drift institucionalizada; expansão do inventário de IA para novos casos de uso; gap assessment concluído para eventual certificação ISO/IEC 42001; reporte semestral ao Conselho de Administração; processo formal de retirement de agentes.	Maturidade dos processos de 180 dias; eventual adequação regulatória ao PL 2338 conforme calendário de aprovação; orçamento recorrente para o AI Risk Office.	Comitê Executivo de IA + AI Risk Office.

8. Referências

Frameworks e standards

- ISO/IEC 42001:2023 — AI Management System.
- NIST AI Risk Management Framework (AI RMF 1.0).
- NIST AI 100-2 — Adversarial Machine Learning: A Taxonomy and Terminology.
- MITRE ATLAS — Adversarial Threat Landscape for Artificial-Intelligence Systems.
- DAMA-DMBOK 2 — Data Management Body of Knowledge.

Regulação

- LGPD — Lei nº 13.709/2018.
- EU AI Act — Regulamento (UE) 2024/1689.
- PL 2338/2023 — Marco da IA no Brasil (em tramitação).

Agentic AI

- OWASP Top 10 for Agentic Applications (2026).
- OWASP Top 10 for LLM Applications (2025).

Estudos e pesquisas de mercado

- Stanford HAI, AI Index Report 2026.
- MIT AI Risk Repository (airisk.mit.edu).
- BCG, Responsible AI Survey 2025.

Casos e precedentes citados

- Mobley v. Workday, Inc. — ação coletiva sobre discriminação algorítmica em recrutamento (certificada em 2025).
- Williams v. City of Detroit — caso de reconhecimento facial e prisão indevida (2020).
- Air Canada v. Moffatt — precedente sobre responsabilidade por respostas de chatbot (2024).